

Executive Summary—Architecture Over Awareness

Target Audience: CISOs, Directors, and IT Leadership

The Problem: Why Training Fails

Current "Adversary-in-the-Middle" (AiTM) tools act as an **Invisible Valet**. They don't steal passwords; they clone authenticated sessions in real-time. Because the attacker mirrors a legitimate login, traditional user awareness cannot stop the "slow-motion click."

The Strategic Shift: Moving the Burden to Math

- **FIDO2 Origin Binding:** Deploy hardware keys (YubiKey, Windows Hello) to high-value targets. These credentials physically cannot sign for a spoofed domain.
- **Token Protection:** Use **TPM 2.0** (Trusted Platform Module) to anchor session cookies to physical hardware. This makes stolen tokens non-exportable and useless to attackers.
- **Updated Playbooks:** Move the standard response from "User Training" to "Architectural Hardening."